CYBERSECURITY FIELD GUIDE

Ransomware Preparedness Guide

Prevention, Detection, Containment, Communication and Recovery

PREPARED BY	Kritika Rani
ORGANIZATION	RedKross Research Foundation
SUBMISSION DEADLINE	25 October 2026
DOCUMENT TYPE	Practical operational guide; companion to the Technical Research Report

PURPOSE

A concise, action-oriented reference to help staff and technical teams reduce ransomware risk, recognise suspicious activity, escalate safely, contain spread and restore trusted services. It is intended for IT teams, SOC analysts, system administrators, security interns and organisational decision-makers.

HOW TO USE THIS GUIDE

Use the prevention checklist as a routine control review. During a suspected incident, follow the organisation's approved incident-response plan and contact the authorised response lead. This guide supports—not replaces—local procedures, specialist advice, legal obligations or management decisions.

PREVENT → DETECT → CONTAIN → INVESTIGATE → RECOVER → VALIDATE → REVIEW

Prepared for authorised defensive use. No live deployment, malware analysis or recovery exercise is claimed by this guide.

1. Ransomware Prevention Checklist

Prioritise the essential controls first. Assign an owner and review date to each item; record exceptions and compensating controls.

ESSENTIAL CONTROLS

■ **Patching and asset inventory.** Maintain an inventory of endpoints, servers, applications and internet-facing services. Apply security updates within risk-based deadlines; prioritise exposed and actively exploited vulnerabilities. Verify deployment and track exceptions.

■ **Multi-factor authentication (MFA).** Require MFA for remote access, email, cloud consoles and privileged accounts. Prefer phishing-resistant MFA where feasible; investigate accounts or services that cannot enforce it.

■ **Least privilege.** Remove standing administrator rights from everyday accounts. Separate user and privileged accounts; review admin groups, service accounts, inactive users and access grants regularly.

■ **Email and phishing.** Use attachment/URL filtering and email authentication controls (SPF, DKIM, DMARC where applicable). Treat unexpected links, attachments, credential prompts and urgent payment requests cautiously; report rather than forward suspicious messages.

■ **Endpoint protection.** Keep centrally managed antivirus/EDR enabled, updated and monitored. Alert on tampering, mass file changes and suspicious script execution; confirm critical endpoints are covered.

■ **Network and remote access.** Segment user endpoints, servers, backup infrastructure and management networks. Restrict RDP and other remote administration to approved gateways, VPN/ZTNA and named users; remove unnecessary exposure.

■ **Backups.** Use 3-2-1 as a baseline: three copies, two media types, one off-site. Add offline or immutable copies; encrypt backups and restrict backup administration with separate accounts and MFA.

■ **Restore testing.** Test restoration of files, databases, applications and full systems on a defined schedule. Confirm integrity and record actual restore time; a successful backup job alone does not prove recoverability.

■ **Logging and monitoring.** Centralise endpoint, identity, server, firewall, cloud and backup logs in a SIEM or equivalent. Alert on privileged access anomalies, security-tool tampering, backup changes and unusual outbound transfer.

ADDITIONAL HARDENING

■ Disable unnecessary services and protocols; restrict macros and untrusted scripts according to business need. Use application control where feasible.

■ Review firewall rules, allow-list administrative paths, and limit east-west traffic between systems.

■ Maintain an approved incident contact list, independent communication channel and tested response plan.

■ Provide short, recurring awareness reminders and make reporting suspicious activity easy and blame-free.

Ownership tip: treat every unchecked essential item as a tracked risk with an owner, target date and documented exception if it cannot be completed promptly.

2. Detection and Initial Response

Common warning signs

Observed signal	Why it matters / what to check
Unexpected mass file edits, renames or encryption	Possible destructive activity; correlate process, user, file path and timestamp.
Ransom note or unfamiliar file extensions	Escalate immediately; preserve the note and affected file details.
New administrator account or privilege change	Validate who created it, the source session and whether it was approved.
Unusual PowerShell or script execution	Review parent process, command context, account, endpoint telemetry and change records.
Security tools disabled, tampered with or logs cleared	Investigate tamper alerts and preserve remaining telemetry.
Backup deletion or unexpected retention/configuration change	Treat as high priority; protect backup consoles and notify the backup lead.
Unusual outbound network transfer	Review destination, volume, timing and authorisation; consider potential data theft.
Repeated failed logins followed by a suspicious success	Check source, device, MFA, session activity and privileged access.

A single indicator is not proof of ransomware. Validate context through authorised responders. Do not delay reporting credible signs of active spread while waiting for certainty.

FIRST-RESPONSE CHECKLIST

1. Recognise and report suspicious activity immediately through the approved IT/security incident channel.

2. Record the detection time and time zone, affected device or service, account (if known), observed symptoms and alert/ticket reference.

3. Notify the authorised IT/security team or SOC; state what is observed and what remains unknown.

4. Follow the organisation’s incident-response plan and instructions from the designated response lead.

5. Do not delete files, clear logs, run unknown tools, open suspicious samples, or make unauthorised configuration changes.

Helpful incident notes

Capture host name/asset ID, reporter contact, first-seen time, screenshots or alert IDs if permitted, suspicious account/process, affected shares, and actions already taken. Store notes and evidence only in approved locations; do not include passwords or unnecessary personal data.

3. Containment, Communication and Safe Escalation

Immediate containment priorities

■ Isolate affected systems from the network using approved EDR or network procedures when safe and authorised. If multiple systems or subnets are affected, responders may need coordinated segmentation.

■ Do not automatically shut down, wipe or reimage devices. Coordinate with qualified responders because volatile evidence may be lost; immediate safety and stopping spread remain priorities.

■ Protect unaffected systems, identity infrastructure, privileged accounts and backup consoles. Restrict compromised accounts and revoke sessions in a coordinated, authorised sequence.

■ Preserve logs, alerts, ransom notes, timestamps and relevant evidence. Record major actions, decisions, approvers and times.

■ Use verified out-of-band communication if corporate email, chat or identity systems may be compromised. Share information only with people who need it.

■ Notify the incident lead promptly. Employees and interns must not negotiate with attackers, pay ransom, run malware samples or perform destructive remediation without explicit authorisation.

Escalation matrix

Situation	Who to contact	Immediate action
Suspicious activity on one endpoint	SOC / designated IT security contact	Report symptoms and asset; follow approved isolation instructions.
Encryption across multiple devices or services	Incident commander, SOC lead, network team	Coordinate containment; protect critical services and evidence.
Privileged account or identity compromise	Identity administrator, security lead, incident commander	Review sessions and access; secure admin paths under direction.
Backup deletion or backup-console compromise	Backup lead, infrastructure lead, incident commander	Protect clean copies; suspend risky changes as authorised.
Possible theft of personal/customer data	Incident commander, legal/privacy lead	Preserve evidence; assess disclosure and notification duties.
Critical service or safety impact	Business continuity lead and operational/safety authority	Prioritise safe continuity and approved alternate processes.
Potential criminal or reportable incident	Legal/compliance and authorised external contact	Confirm applicable reporting duties, deadlines and channels.

Communication rules

Appoint an incident commander and authorised spokesperson. Separate confirmed facts from hypotheses; provide the next update time; avoid speculation and public disclosure of sensitive details. Legal/privacy teams should assess applicable obligations. In India, CERT-In's 28 April 2022 directions include a six-hour reporting requirement for specified incidents for covered entities; confirm applicability, current wording and channel with legal/compliance. A public complaint does not necessarily replace separate regulatory reporting.

4. Recovery and Business Continuity

Restore trust—not just files. Do not reconnect systems until authorised responders have addressed the compromise and approved return to service.

Recommended recovery sequence

1. Confirm containment and determine the scope: affected endpoints, servers, accounts, cloud resources, shared storage and potential data exposure.

2. Check whether privileged credentials, identity systems, backup consoles or recovery copies were compromised.

3. Remove the root cause: close the initial-access path, remediate exploited vulnerabilities and persistence, and rebuild compromised systems from trusted images where appropriate.

4. Prepare a clean recovery environment. Verify backup provenance, integrity and isolation before restoring.

5. Restore services in dependency order according to business priorities (identity and core dependencies first where applicable). Reset compromised credentials and revoke attacker sessions.

6. Validate application function, data integrity, permissions, endpoint protection, logging and monitoring.

7. Reconnect in controlled stages after documented technical and business approval. Monitor for recurrence or renewed attacker activity.

8. Record recovery outcomes, unresolved risks, decisions and corrective actions.

Recovery objectives in plain language

RPO — Recovery Point Objective	How much data loss, measured in time, the organisation can tolerate. Example: a 4-hour RPO means the target restore point is no more than four hours before disruption.
RTO — Recovery Time Objective	How long a service may be unavailable before it should be restored. Example: an 8-hour RTO means the target is to restore the service within eight hours of the defined disruption point.

Backup-readiness checklist

- ■ Critical systems/data are inventoried; owners, retention and RPO/RTO are documented.
- ■ At least one offline or immutable copy is isolated from normal admin credentials and production compromise.
- ■ Backup administration uses separate, strongly protected accounts; access and retention changes are logged.
- ■ Restore tests cover representative files, databases, applications and full systems; results and actual durations are recorded.
- ■ Recovery keys, system configurations and identity dependencies are protected and available to authorised recovery staff.

Post-incident review checklist

- ■ Build a timeline; identify entry path, scope, control gaps and any data exposure.
- ■ Review response speed, escalation, communication, evidence handling and business continuity decisions.
- ■ Document what worked, what failed, and what remains uncertain.
- ■ Assign each corrective action an owner, deadline and evidence of completion; update playbooks and exercise them.

5. Quick Reference and Sources

QUICK-REFERENCE CHECKLIST

BEFORE AN INCIDENT	DURING A SUSPECTED INCIDENT
■ Patch and inventory critical assets. ■ Enforce MFA and least privilege. ■ Segment networks and restrict remote access. ■ Maintain offline/immutable backups. ■ Test restores and record RPO/RTO. ■ Confirm contacts, authority and out-of-band channel. ■ Centralise endpoint, identity, network and backup logs.	■ Report promptly; record time, asset and symptoms. ■ Follow the approved response plan. ■ Isolate affected systems when safe and authorised. ■ Protect backups and privileged accounts. ■ Preserve logs, alerts and ransom notes. ■ Use verified channels; limit sensitive sharing. ■ Do not negotiate, pay, run samples or wipe systems without authorisation.
DURING RECOVERY	**AFTER RECOVERY**
■ Confirm scope and containment. ■ Remediate entry path and persistence. ■ Restore only from verified clean sources. ■ Reset compromised credentials. ■ Validate integrity, access controls, EDR and logs. ■ Obtain approval before reconnection.	■ Monitor for renewed access or encryption. ■ Record recovery results and remaining risks. ■ Complete a lessons-learned review. ■ Assign corrective actions, owners and deadlines. ■ Update and rehearse the response plan.

Response flow

DETECT	REPORT	CONTAIN	INVESTIGATE	RECOVER	VALIDATE	REVIEW

Authoritative references

1. NIST (2026), *Ransomware Risk Management: A Cybersecurity Framework 2.0 Community Profile*, NIST IR 8374 Rev. 1, final 11 June 2026.
https://csrc.nist.gov/pubs/ir/8374/r1/final

2. NIST (2025), *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*, SP 800-61 Rev. 3, final April 2025.
https://csrc.nist.gov/pubs/sp/800/61/r3/final

3. CISA and partner agencies, *#StopRansomware Guide* (guide page; published guide updated May 2023).
https://www.cisa.gov/stopransomware/ransomware-guide

4. NIST, *The NIST Cybersecurity Framework (CSF) 2.0*, NIST CSWP 29 (2024).
https://www.nist.gov/cyberframework

5. CERT-In, *Directions under Section 70B(6) of the Information Technology Act, 2000* (28 April 2022), and associated FAQs. Verify applicability/current requirements at time of use.
https://www.cert-in.org.in/Directions70B.jsp

6. MITRE, *ATT&CK; Enterprise Matrix* (living knowledge base; use for defensive detection context).
https://attack.mitre.org/

7. Government of India, *National Cyber Crime Reporting Portal* (public cybercrime complaints; not a substitute for checking regulatory duties).
https://www.cybercrime.gov.in/

Document note: This practical guide was prepared to complement the separate Ransomware Preparedness Technical Research Report supplied for this assignment. It is a recommended operating aid, not evidence of a live deployment, audit, test or incident. Adapt procedures to approved organisational policy and seek qualified legal/incident-response advice as needed.